

Week 7

Introduction

In our increasingly interconnected world, where digital interactions form the backbone of commerce, communication, and daily life, the fundamental need for trust, authenticity, and integrity cannot be overstated. Every email sent, every online transaction, and every piece of data exchanged relies on an invisible layer of security to ensure it reaches its destination unaltered and from a verified source. This week, we delve into the critical mechanisms that underpin this digital trust: cryptographic hash functions, digital signatures, and the robust protocols that integrate them into our internet infrastructure. Understanding these concepts is not merely an academic exercise; it's about grasping the foundational tools that protect our privacy, safeguard our data, and verify identities in a world where physical presence cannot always be confirmed.

This week's lectures build from the core principles of one-way functions to their sophisticated applications in securing complex systems. We begin by exploring the properties and types of cryptographic hash functions, which are essential for data integrity and authentication. We then advance to the intricate world of digital signatures and certificates, which provide verifiable authenticity and non-repudiation, much like a physical signature. Finally, we examine how these cryptographic primitives are integrated into widely used security protocols such as SSL/TLS, SSH, and IPsec, demonstrating their indispensable role in securing the vast and often vulnerable landscape of the internet.

Core Concepts

Term	Definition	Significance
Cryptographic Hash Function	A mathematical function that transforms an input message of arbitrary length into a fixed-length output (hash value or digest) with specific properties suitable for security applications.	Forms the backbone of digital signatures, message authentication codes, and password storage, crucial for modern cybersecurity.
Collision Resistance	The property of a cryptographic hash function where it is computationally	The strongest resistance property, vital for digital signature security, making it

Term	Definition	Significance
	infeasible to find any two distinct messages that produce the same hash value.	extremely difficult for attackers to create two messages with identical hashes.
Digital Signature	A mathematical scheme for verifying the authenticity of digital messages or documents, providing the digital equivalent of a handwritten signature.	Ensures message integrity, sender authenticity, and non-repudiation in digital communications.
Private Key	A secret cryptographic key known only to its owner, used for signing digital documents or decrypting messages in public-key cryptography.	Essential for generating digital signatures, as it uniquely identifies the signer and cannot be replicated by others.
Public Key	A cryptographic key that can be widely distributed and is used to verify digital signatures or encrypt messages for the private key owner.	Allows anyone to verify a digital signature or send encrypted messages to the private key owner without needing the private key itself.
Digital Certificate	An electronic document issued by a trusted third party (Certification Authority) that binds a public key to an identified entity (person, organization).	Establishes trust in public keys by verifying their association with specific entities, crucial for secure online interactions.
SSL (Secure Socket Layer)	A protocol (now largely superseded by TLS) that provides an optional layer of security for data transmitted over TCP/IP networks.	Ensures data privacy, integrity, and authentication for internet communications, preventing eavesdropping and tampering.
	An extension of SSL, providing security and data	Ensures secure, end-to-end communication between web

Term	Definition	Significance
TLS (Transport Layer Security)	integrity at the transport layer for web applications and other network services.	servers and browsers, protecting sensitive data.
IPsec (IP Security)	A suite of protocols that provides secure packet transfer at the IP layer level, offering host-to-host or firewall-to-firewall encryption and authentication.	Offers comprehensive network security, crucial for securing network infrastructure and mandatory for IPv6.
HMAC	Hash-based Message Authentication Code, a specific construction for calculating a message authentication code (MAC) involving a cryptographic hash function and a secret key.	Offers message authentication and integrity without relying on slower encryption algorithms, making it efficient for verifying data origin and preventing tampering.

Detailed Analysis

1. Lecture 31 : Cryptographic hash functions (Part I)

This lecture introduced the foundational concept of hash functions, which transform arbitrary-length input messages (M) into fixed-length hash values (H). A key distinction was made between general hash functions and **Cryptographic Hash Functions**, which possess specific properties making them suitable for security. Authentication, the process of verifying a sender's identity, was highlighted as a primary application.

Hash functions were categorized into two main types:

- **Unkeyed Hash Functions (Modification Detection Codes - MDCs)**: These are used primarily for message integrity.
 - The sender computes $H(M)$ and appends it to M .
 - The receiver recomputes $H(M')$ from the received message M' and compares it to the received MDC. A match confirms integrity.
 - MDCs detect modifications but do not authenticate the sender.
- **Keyed Hash Functions (Message Authentication Codes - MACs)**: These provide both message integrity and sender authentication using a shared secret key

(K).

- The sender computes $F(M, K)$ (where F is the MAC algorithm) and appends it to M .
- The receiver recomputes $F(M', K)$ and compares it to the received MAC. A match confirms both integrity and authenticity.

For a hash function to be cryptographic, it must exhibit several desirable properties:

- **Applicability to Arbitrary-Sized Messages:** Can process inputs of any length.
- **Fixed-Length Output:** Always produces a hash of a predetermined size.
- **Computational Efficiency:** Easy and fast to compute $H(x)$.
- **First Preimage Resistance (One-Way Property):** Given y , it's infeasible to find x such that $H(x) = y$.
- **Second Preimage Resistance (Weak Collision Resistance):** Given x , it's infeasible to find $x' \neq x$ such that $H(x) = H(x')$.
- **Collision Resistance (Strong Collision Resistance):** It's infeasible to find any $x \neq x'$ such that $H(x) = H(x')$. This is the strongest property.

Examples of hash function families discussed included the MD family (e.g., MD5, now considered weak due to collision vulnerabilities), the SHA family (e.g., SHA-1, SHA-256, SHA-512, SHA-3), and the RIPEMD family.

2. Lecture 32 : Cryptographic hash functions (Part II)

Building on the properties, this lecture explored diverse applications and advanced algorithms.

- Applications of One-Way Hash Functions:

- **Password Storage:** Systems store password hashes, not plaintext, to protect against database breaches.

- Authentication and Message Integrity using Symmetric-Key Encryption:

The sender hashes the message, encrypts the hash with a shared secret key, and sends both. The receiver decrypts the hash and compares it with a recomputed hash of the message. This provides authentication and integrity but is slower than pure hashing.

- Authentication and Message Integrity using Public-Key Encryption (Digital Signatures):

The sender hashes the message and encrypts the hash with their private key (creating a digital signature). The receiver uses the sender's public key to decrypt the signature and compares it to a recomputed hash of the message. This offers non-repudiation but is the slowest method.

- **Authentication and Message Integrity without Encryption:** A shared secret key (K) is appended to the message (M) before hashing ($H(M || K)$). The message and hash are sent. The receiver, possessing K , recomputes the hash and compares. This is efficient as it avoids encryption.

- **SHA-512 Hash Function:** A detailed look at a robust algorithm.

- **Message Preprocessing:** Messages are padded to a length multiple of 1024 bits, then divided into 1024-bit blocks.
- **Iterative Hashing:** Each block is processed sequentially using a compression function (F) with an initial 512-bit hash value. The output of one block becomes the input for the next.
- **Compression Function (F):** Involves 80 rounds of complex bitwise operations, using a 512-bit buffer and unique round constants derived from prime numbers.
- The SHA family includes versions like SHA-1 (160-bit), SHA-256 (256-bit), and SHA-512 (512-bit), differing in digest length, block size, and number of rounds.
- **HMAC (Hash-based Message Authentication Code):** A construction for MACs that uses existing hash functions efficiently without encryption.
- It involves a two-step hashing process with a secret key (K) and distinct padding blocks (Q and P).
- $$\text{HMAC} = H((K \parallel P) \parallel H((K \parallel Q) \parallel M))$$
- This provides strong integrity and authentication efficiently.
- **Attacks on Hash Functions:** The primary concern is finding collisions.
- **Birthday Attack:** Exploits the birthday paradox, allowing collisions to be found in approximately $2^{(n/2)}$ attempts for an n -bit hash, rather than 2^n . This necessitates larger hash digest lengths (e.g., 128 bits for 64-bit security).

3. Lecture 33 : Digital signature and certificate

This lecture focused on **Digital Signatures** as the digital equivalent of handwritten signatures, providing authenticity, integrity, and non-repudiation. They are built upon public-key cryptography.

- **Signature Generation:** The sender computes a hash $m = H(M)$ of the message M , then "signs" m using their private key d to produce the signature $S = f_s(m, d)$. M and S are transmitted.
- **Signature Verification:** The receiver computes $m' = H(M)$ from the received message and uses the sender's public key e to transform S back to $m_{\text{prime_from_S}} = f_v(S, e)$. If $m' == m_{\text{prime_from_S}}$, the signature is verified.
- **Types of Digital Signatures:**
 - **Signature with Appendix:** Most common, signs only the hash, appended to the message.
 - **Signature with Message Recovery:** Encrypts the entire message with the private key; less common due to computational cost.
 - **Deterministic vs. Probabilistic:** Deterministic signatures always produce the same output for a given message/key; probabilistic introduce randomness.
 - **Blind Signatures:** Allow a signer to sign a message without knowing its content, useful for privacy (e.g., digital cash).
 - **Undeniable Signatures:** Require signer's active participation for verification.

- **Attacks on Digital Signatures:** Include total break (private key compromise), selective forgery, existential forgery, key-only attacks, known message attacks, and chosen message attacks.
- **Digital Certificates:** Crucial for establishing trust in public keys.
- A certificate binds a public key to an identified entity.
- **Certification Authorities (CAs)** are trusted third parties that issue and digitally sign certificates, vouching for the identity of the certificate holder.
- Certificates contain entity details, public key, CA name, validity period, serial number, and the CA's digital signature.
- **Certificate Revocation:** Certificates can be invalidated before expiry due to compromise, information change, or expiry. CAs maintain a **Certificate Revocation List (CRL)**.
- **X.509 Standard:** The widely adopted format for digital certificates.
- **Elliptic Curve Cryptography (ECC):** An alternative to RSA, offering comparable security with smaller key sizes and faster computations, ideal for resource-constrained devices.

4. Lecture 34 : Applications (Part I)

This lecture introduced the **Secure Socket Layer (SSL)** protocol, a foundational application for securing internet communications, now largely evolved into **Transport Layer Security (TLS)**.

- **SSL Overview:** An optional layer above TCP/IP, providing authentication, data integrity, and data privacy (encryption/decryption). It secures protocols like HTTP (leading to HTTPS), LDAP, and POP3.
- **SSL Architecture:** Comprises two layers:
- **SSL Record Protocol:** The lower layer, responsible for fragmentation (max 16KB), compression, MAC generation, encryption, and adding an SSL header before passing data to TCP.
- **Higher-Layer Protocols:**
- **SSL Handshake Protocol:** The most complex, establishing a secure session, negotiating cryptographic algorithms, exchanging keys, and performing mutual authentication in four phases:
 - Phase 1: Client and Server Hello messages exchange capabilities.
 - Phase 2: Server authentication (certificate) and key exchange.
 - Phase 3: Client authentication (certificate) and key exchange (pre-master secret encrypted with server's public key).
 - Phase 4: Finish Handshake with `ChangeCipherSpec` and `Finished` messages from both parties.
- **SSL ChangeCipherSpec Protocol:** A single message signaling the immediate activation of newly negotiated cryptographic parameters.

- **SSL Alert Protocol:** Conveys warnings or fatal errors, potentially terminating the session.
- **SSL-Based Services:** Common examples include HTTPS (port 443), LDAPS (port 646), SMTPS (port 463), and POP3S (port 995).

5. Lecture 35 : Applications (Part II)

This lecture continued the discussion on practical applications, focusing on **TLS**, **SSH**, and **IPsec**, and clarifying the distinction between S-HTTP and HTTPS.

- **TLS (Transport Layer Security):** The modern successor to SSL, specifically designed for end-to-end security at the transport layer for web applications.
- **SSH (Secure Shell):** A robust protocol for secure remote login and command execution, replacing insecure protocols like Telnet.
- **Key Features:** Port Forwarding/Tunneling, Proxy and Firewall configuration.
- **Key Management (SSHv1 example):** Uses a **Long-term Key** (e.g., 1024/2048-bit RSA) for server identification and initial authentication, and a frequently refreshed **Short-term Encryption Key** (e.g., 768-bit RSA) for data encryption, enhancing forward secrecy.
- **Authentication Mechanisms:** Supports encrypted passwords, RSA-based authentication, challenge-response, and add-on mechanisms like biometrics.
- **IPsec (IP Security):** A suite of protocols providing security directly at the IP layer, mandatory for IPv6.
- **Services:** Authentication and Integrity (verifies origin, detects modification), Confidentiality (encryption), and Replay Protection.
- **Modes of Operation:**
 - **Tunnel Mode:** Encapsulates and encrypts the entire original IP packet, often used for VPNs between networks.
 - **Transport Mode:** Encapsulates and protects only the transport layer payload, used for end-to-end host communication.
- **Drawbacks:** Performance overhead, complexity, and historical issues with NAT.
- **NAT (Network Address Translation):** A mechanism to translate private IP addresses to public ones, allowing multiple internal devices to share a single public IP.
- **S-HTTP vs. HTTPS:**
 - **S-HTTP (Secure HTTP):** An extension of HTTP designed to secure individual HTTP messages (requests/responses), offering flexible security mechanisms.
 - **HTTPS (Hypertext Transfer Protocol Secure):** Refers to HTTP running on top of a secure transport layer protocol (SSL/TLS), securing the entire communication channel between browser and server. HTTPS is the standard for secure web browsing.

Key Takeaways

- [] Cryptographic hash functions provide fixed-length outputs from arbitrary-length inputs and are essential for data integrity and authentication.
- [] Key properties of cryptographic hash functions include First Preimage Resistance, Second Preimage Resistance, and Collision Resistance.
- [] MACs (keyed hash functions) offer both message integrity and sender authentication, while MDCs (unkeyed hash functions) only provide integrity.
- [] Digital signatures use public-key cryptography to provide authenticity, integrity, and non-repudiation, with the private key signing and the public key verifying.
- [] Digital certificates, issued by Certification Authorities (CAs), bind public keys to identities, establishing trust in public-key infrastructure.
- [] SSL/TLS is a layered protocol that secures internet communications by providing authentication, data integrity, and data privacy (encryption).
- [] The SSL/TLS Handshake Protocol is a multi-phase process for negotiating cryptographic parameters and authenticating parties.
- [] SSH provides secure remote access and command execution, using both long-term and frequently refreshed short-term keys for enhanced security.
- [] IPsec secures communications at the IP layer, offering authentication, integrity, confidentiality, and replay protection in both Tunnel and Transport modes.
- [] HTTPS, which is HTTP over SSL/TLS, secures the entire communication channel for web browsing, distinguishing it from S-HTTP which secures individual messages.

Conclusion

This week's exploration has unveiled the intricate tapestry of cryptographic tools and protocols that form the bedrock of digital security. From the fundamental concept of a one-way hash function, which ensures data integrity and protects passwords, to the sophisticated mechanisms of digital signatures and certificates that verify identities and prevent repudiation, we've seen how mathematical principles translate into tangible security benefits. The journey culminated in understanding how these primitives are woven into essential internet protocols like SSL/TLS, SSH, and IPsec, which silently safeguard our web browsing, remote access, and network communications every single day.

The continuous evolution of these technologies, driven by the need to counter ever-more sophisticated threats, underscores the dynamic nature of cybersecurity. As our

reliance on digital systems deepens, the principles of authentication, integrity, and confidentiality, championed by these cryptographic solutions, will remain paramount. They are the unseen guardians, enabling trust and privacy in a world where information flows freely, yet securely, across vast and complex networks. This foundational knowledge is indispensable for anyone seeking to navigate, build, or protect the digital future.